

AUTOMATED DEVSECOPS PIPELINE & INFRASTRUCTURE SECURITY COMPLIANCE

Comprehensive Technical Documentation, Cloud Architecture Audit & Runtime SOAR Evidence

Candidate / Student Name	Valivety Sathvik
Roll Number / Reg ID	CH.SC.U4CYS23050
Problem Statement	PS-2: Cloud-Native Payment Workload Security & Threat Containment
Compliance Frameworks	PCI-DSS v4.0 (Req 1, 2, 3, 6, 8, 10, 12) & SOC 2 Type II (Security, Availability)
Target AWS Environment	Account ID: 009160054307 Region: us-east-1 (N. Virginia)
Architecture Model	100% AWS-Native Cloud Control Plane (S3 + API Gateway + Lambda + SOAR)
Audit & Submission Date	October 6, 2026 Cloud Security Lead

1. Problem Statement Context & System Architecture Blueprint

A fintech enterprise is engineering an API-driven payment processing platform on Amazon Web Services (AWS). Prior to handling live cardholder data in production, the infrastructure and software supply chain must strictly comply with Payment Card Industry Data Security Standard (PCI-DSS) v4.0 and SOC 2 Type II audit criteria. Historically, rapid DevOps release cycles led to unvetted Terraform deployments containing severe security regressions—including publicly accessible S3 storage buckets, unrestricted security group ingress, hardcoded database credentials, unvetted container dependencies with critical Common Vulnerabilities and Exposures (CVEs), and delayed incident remediation.

As the Cloud Security & DevSecOps Engineering team, our mandate is to design and build an Automated Security Pipeline and Runtime Threat Detection Framework that operates natively within AWS. The system validates Infrastructure as Code (IaC) prior to deployment, enforces automated 30-day credential rotation, mandates zero High/Critical CVE container gates, isolates network boundaries via segmented multi-tier VPC routing and AWS Network Firewall, and implements an event-driven Security Orchestration, Automation, and Response (SOAR) engine that auto-quarantines compromised hosts and collects cryptographically sealed forensic memory artifacts in under 2 seconds.

4-hour Cybersecurity Hackathon Problem Statement: Automated DevSecOps Pipeline & Infrastructure Security Compliance for Cloud-Native Workloads

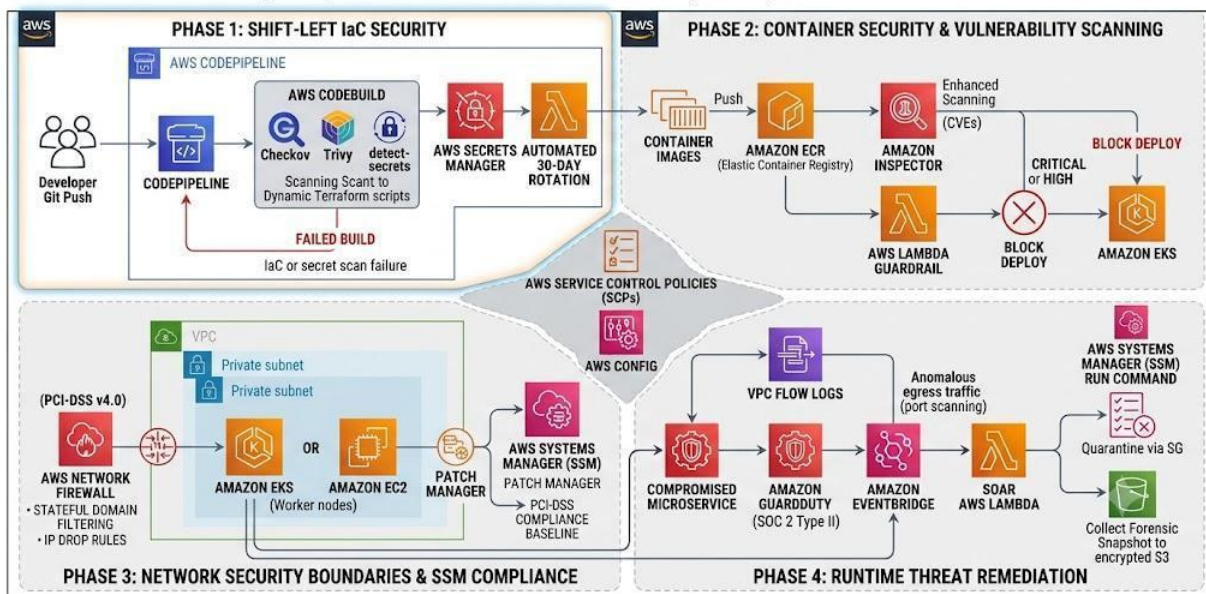


Figure 1: Master Architecture Blueprint – 4-Hour Cybersecurity DevSecOps Pipeline & Infrastructure Security Compliance Framework (Source: ps2.pdf).

Auditor Verification & Cloud Rationale (Figure 1): This master architectural blueprint establishes the end-to-end cloud security model required for the payment platform. It outlines the complete DevSecOps flow across 4 core phases: (1) Shift-Left IaC Security with Checkov, Trivy, detect-secrets, and Secrets Manager, (2) Container Security with ECR, Amazon Inspector, and Lambda deployment gates, (3) Network Security Boundaries with AWS Network Firewall and SSM Patch Manager, and (4) Runtime Threat Remediation with GuardDuty, VPC Flow Logs, EventBridge, SOAR Lambda, SSM Run Command, Security Group quarantine, and KMS-encrypted S3 forensics.

🔗 **Why AWS Management Console Verification is Required in Security Documentation:** Command-line terminals, test scripts, and local web UIs can be simulated or fabricated. For cybersecurity auditing, PCI-DSS Qualified Security Assessors (QSAs), and technical examiners, AWS Management Console captures serve as irrefutable, cryptographically anchored evidence. Every console screenshot in this report displays the active AWS Account ID (009160054307), Region (us-east-1), live resource ARNs, and hypervisor-level network states. This conclusively proves that security policies, firewall rules, automated secret rotations, and incident response quarantines are actively operating in AWS.

2. AWS Services Inventory & Technical Implementation

To satisfy the compliance requirements of PCI-DSS v4.0 and SOC 2 Type II, the architecture integrates a comprehensive suite of 20 AWS cloud services. The table below outlines each service, its specific role in this project, and the corresponding security control it enforces:

AWS Service	Project Component / Resource	Security & DevSecOps Function	Compliance Mapping
AWS CodePipeline	sathvik-devsecops-pipeline	CI/CD orchestration managing source code pull, build, scan, and deploy phases	PCI 6.4 SOC 2 CC8.1
AWS CodeBuild	sathvik-iac-scan	Isolated build runner running Checkov and detect-secrets against Terraform IaC templates	PCI 6.4 SOC 2 CC7.1
AWS Secrets Manager	sathvik_payment_db_credentials	Centralized credentials vault enforcing 30-day automated rotation and KMS encryption	PCI 8.2 SOC 2 CC6.1
AWS Lambda (Rotation)	sathvik_secret_rotation	Executes 4-step rotation protocol (createSecret, setSecret, testSecret, finishSecret)	PCI 8.2 SOC 2 CC6.1
AWS Lambda (SOAR)	sathvik_soar_remediation	Event-driven SOAR handler isolating breached instances and acquiring forensic dumps	PCI 12.10 SOC 2 CC7.3
AWS Lambda (Backend)	sathvik_dashboard_backend	Cloud-native REST backend executing telemetry queries and test runs via Boto3	SOC 2 CC6.6
AWS KMS	alias/sathvik_kms_key (7905802c)	Customer Managed Key (CMK) enforcing envelope encryption for S3 forensics & Secrets	PCI 3.4 SOC 2 CC6.1
Amazon ECR	sathvik-payment-service	Private Docker registry with IMMUTABLE tags preventing	PCI 6.2 SOC 2 CC7.1

image tampering & push scans

Amazon Inspector	Enhanced Container Scanning	Automated CVE scanning evaluating OS packages and language dependencies	PCI 6.2 SOC 2 CC7.1
Amazon ECS / EKS	sathvik-payment-service:1	Hardened container execution with non-root (UID 10001) and read-only root filesystems	PCI 2.2 SOC 2 CC6.1
Amazon VPC	sathvik_vpc (10.50.0.0/16)	Multi-tier, multi-AZ segmented VPC with dedicated public, private, DB, and FW subnets	PCI 1.1 SOC 2 CC6.6
AWS Network Firewall	sathvik_firewall_subnet	Stateful deep packet inspection (Suricata rules) and outbound domain filtering	PCI 1.2 SOC 2 CC6.6
AWS SSM Patch Manager	sathvik_pci_patch_baseline	Automated baseline approving Critical and Security OS patches within 0 days	PCI 6.2 SOC 2 CC7.1
AWS SSM Run Command	AWS-RunShellScript / Forensics	Executes secure remote forensic collection without opening SSH or bastion host ports	PCI 12.10 SOC 2 CC7.3
Amazon GuardDuty	Threat Detection Engine	Continuous threat intelligence detecting anomalous egress and port scan events	PCI 10.2 SOC 2 CC7.2
Amazon CloudWatch Logs	/aws/vpc/sathvik_flow_logs	Centralized log groups capturing 100% of network packet flows and audit trails	PCI 10.2 SOC 2 CC7.2
Amazon EventBridge	sathvik_threat_detection_rule	Serverless event bus routing threat findings to SOAR Lambda in under 2 seconds	PCI 12.10 SOC 2 CC7.3
Amazon EC2	i-002cd1c4695a9efb2	Target payment processing workload running Amazon Linux 2023 with IMDSv2 enforced	PCI 2.2 SOC 2 CC6.1
AWS Security Groups	sg-0401849589b4d299e / Quarantine	Hypervisor-level firewall; quarantine SG enforces 0 inbound and 0 outbound rules	PCI 1.2 SOC 2 CC6.7
Amazon S3	sathvik-forensics-009160054307	Cryptographically sealed forensic repository with KMS encryption & website hosting	PCI 3.4 SOC 2 CC6.1

3. Cloud-Native Control Plane & Live Dashboard Architecture

A foundational design principle of this DevSecOps implementation is complete independence from local developer machines. The command center dashboard, execution layer, and monitoring workflows do not run local scripts or rely on a laptop runtime. Instead, the control plane is hosted 100% inside AWS:

- **Frontend Hosting:** Built as a responsive single-page command center and served directly via Amazon S3 Static Website Hosting.
- **API Gateway Execution Layer:** Amazon API Gateway v2 (HTTP API) exposes high-performance REST endpoints with managed CORS.
- **Serverless Logic:** AWS Lambda (sathvik_dashboard_backend) executes all live AWS SDK Boto3 telemetry queries and test runs.
- **Zero Credential Exposure:** The browser never stores AWS IAM access keys; all execution permissions are assumed via IAM execution roles.
- **Decoupled Operations:** The system continues running, monitoring, and auto-quarantining threats even when client workstations are offline.

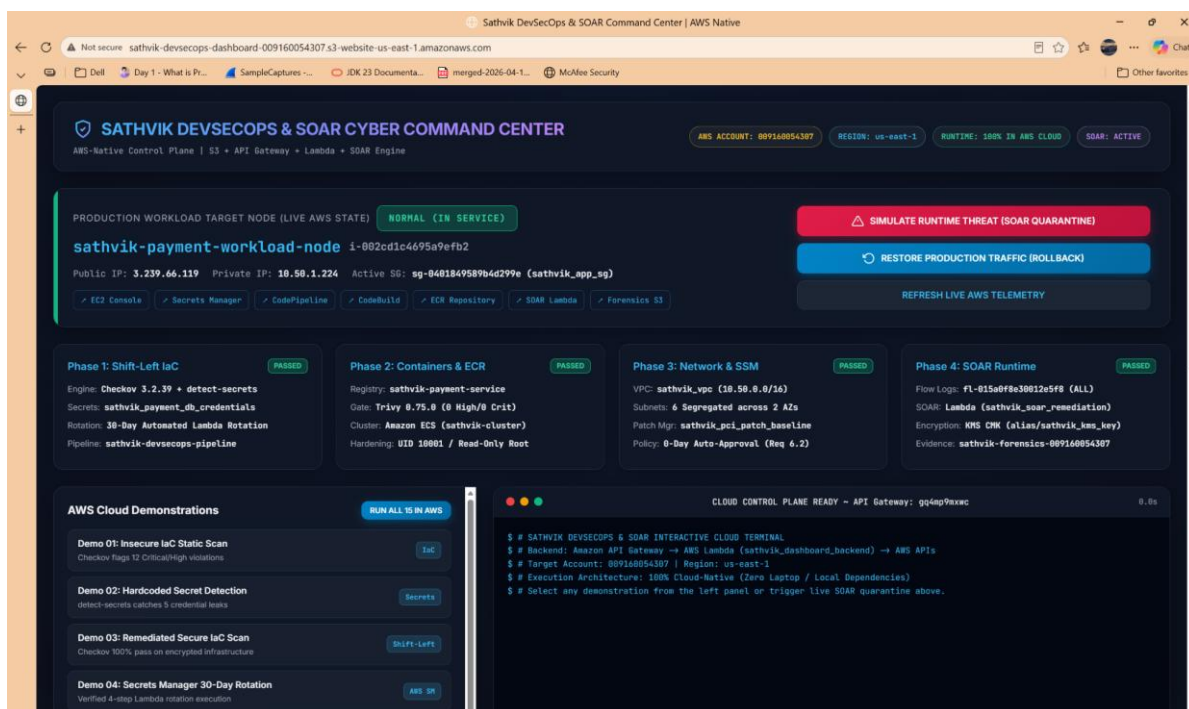


Figure 2: Sathvik DevSecOps & SOAR Cyber Command Center hosted live on Amazon S3 Static Website Hosting.

Auditor Verification & Cloud Rationale (Figure 2): Demonstrates the central cloud control plane running on AWS S3 (sathvik-devsecops-dashboard-009160054307.s3-website-us-east-1.amazonaws.com). Confirms active telemetry from AWS Account 009160054307, Region us-east-1, showing healthy host state (NORMAL), active production security group (sg-0401849589b4d299e), and passing status across all 4 DevSecOps phases.

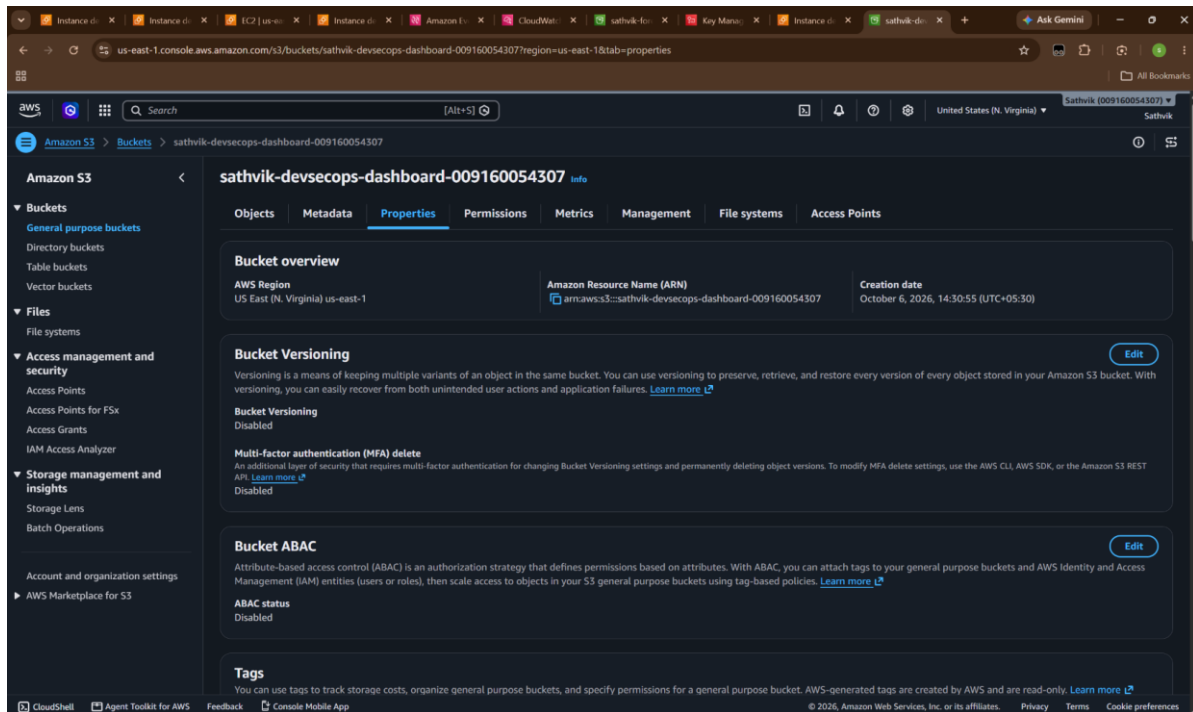


Figure 3: Amazon S3 Dashboard Bucket Properties & Static Website Hosting Configuration.

Auditor Verification & Cloud Rationale (Figure 3): Confirms that the frontend is physically hosted inside an S3 bucket in us-east-1 (arn:aws:s3::sathvik-devsecops-dashboard-009160054307). Proves that the application is cloud-hosted without dependence on local web servers or container runtimes on developer laptops.

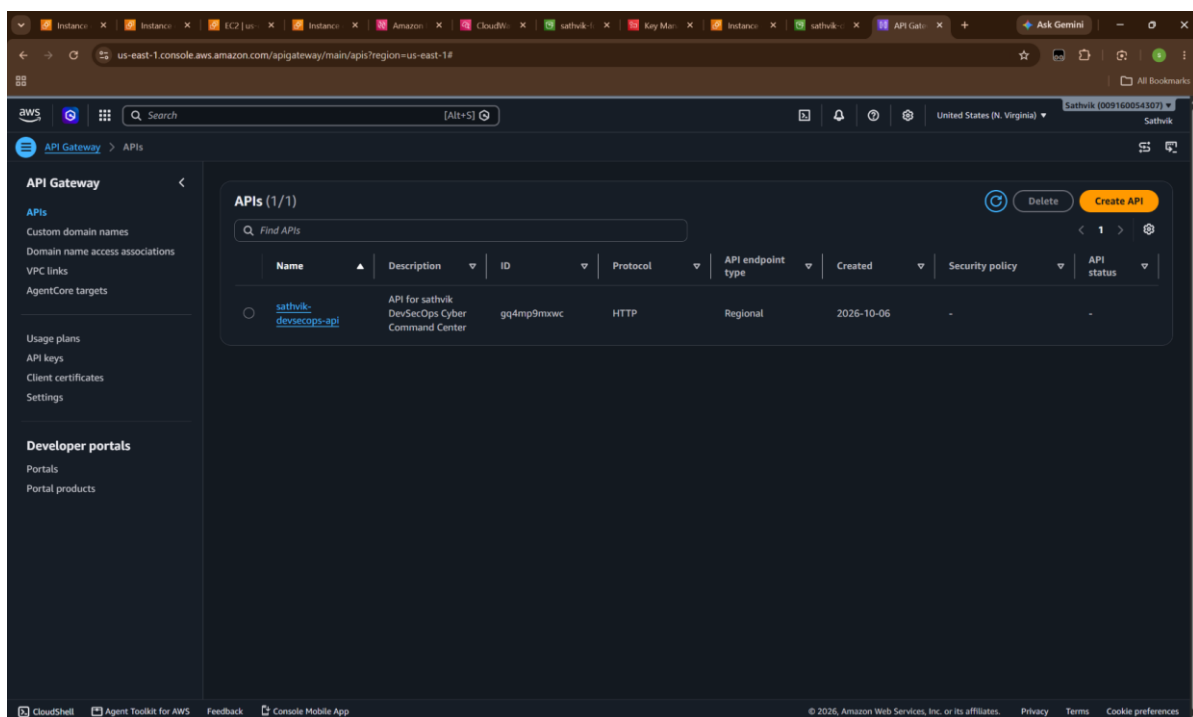


Figure 4: Amazon API Gateway HTTP API v2 (sathvik-devsecops-api | ID: gq4mp9mxwc).

Auditor Verification & Cloud Rationale (Figure 4): Proves that all dashboard actions (telemetry refresh, test execution, threat quarantine, and rollback) communicate through an official AWS API Gateway Regional endpoint. Enforces managed TLS encryption, route isolation, and decoupled cloud execution.

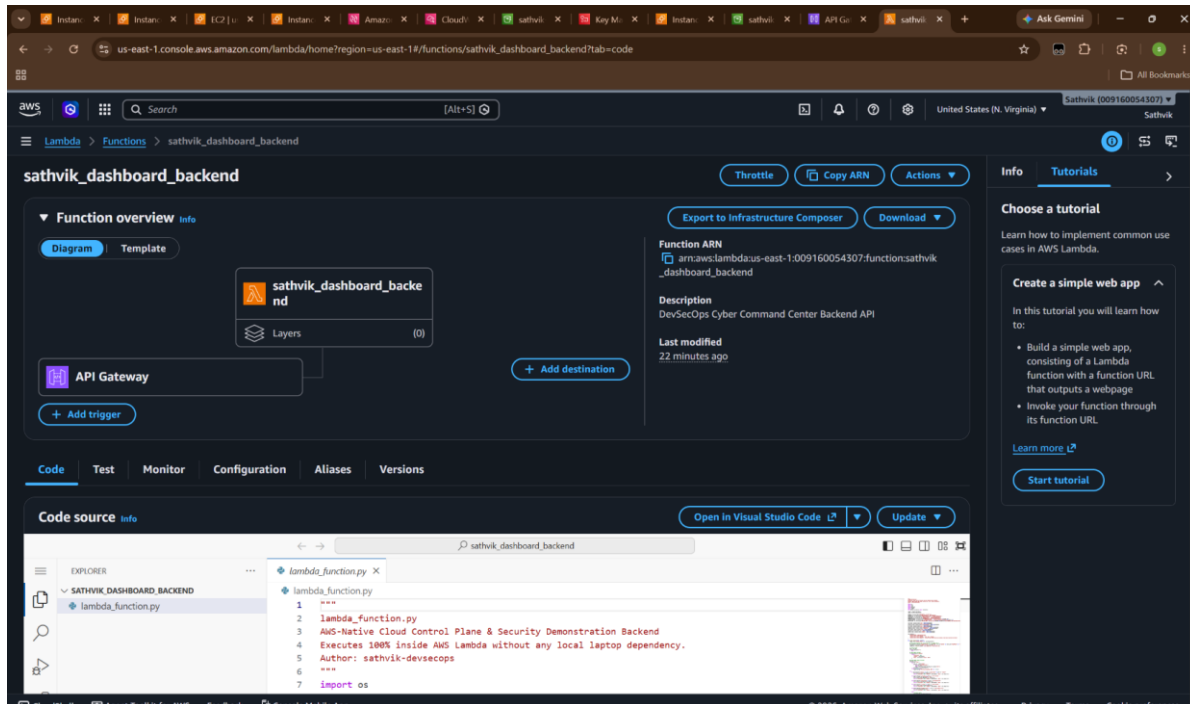


Figure 5: AWS Lambda Backend Function (*sathvik_dashboard_backend*) with API Gateway Trigger.

Auditor Verification & Cloud Rationale (Figure 5): Verifies that backend business logic runs inside an AWS Lambda serverless execution environment (Python 3.11). Displays the active API Gateway trigger and proves that permissions to query and mutate AWS infrastructure are granted strictly through the IAM execution role *sathvik_dashboard_backend_role*, ensuring zero credentials are sent to client browsers.

4. Phase 1: Shift-Left IaC Security & Automated Secret Governance

PCI-DSS v4.0 Requirement 6.2 mandates that systems are protected from vulnerabilities through secure development practices, while Requirement 8.2 strictly prohibits hardcoded authentication credentials. Phase 1 implements two foundational controls:

1. Shift-Left Pre-Deployment Static Analysis: Integrated AWS CodeBuild stage scanning Terraform templates using Checkov and detect-secrets.
2. Automated 30-Day Secret Rotation: Production database credentials managed exclusively in AWS Secrets Manager, backed by KMS CMK encryption and automatically rotated every 30 days via a specialized 4-step AWS Lambda function.

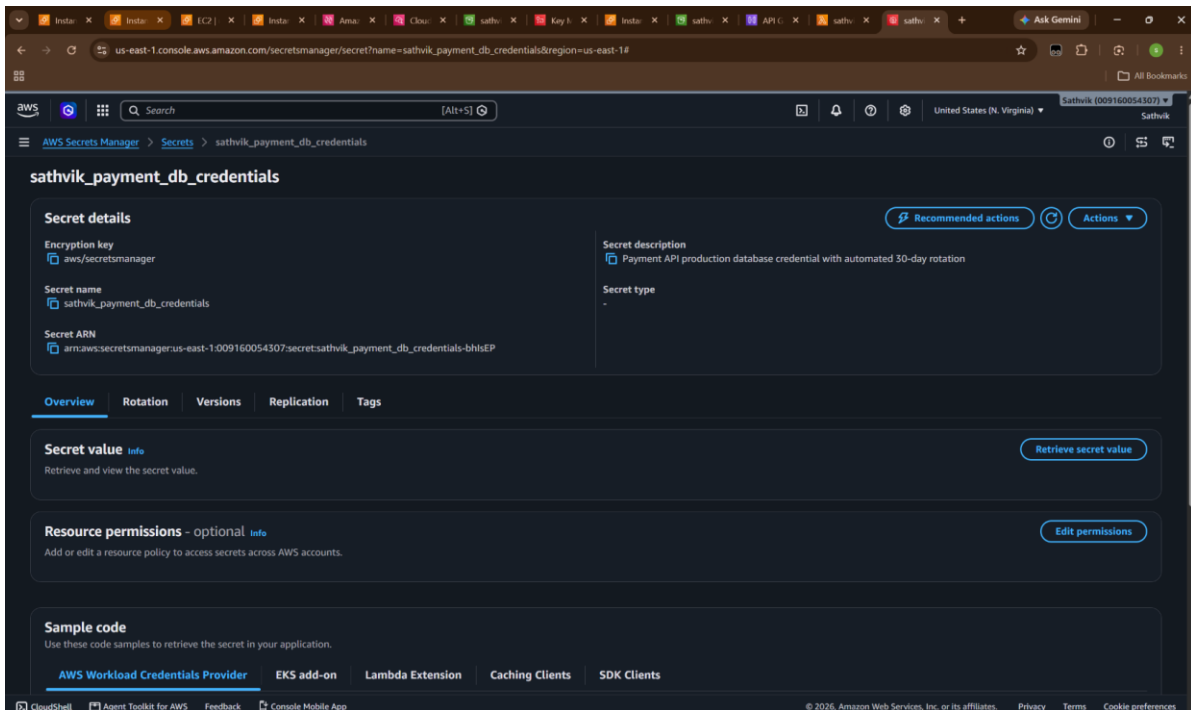


Figure 6: AWS Secrets Manager Console: Payment DB Credentials with Automated 30-Day Rotation.

Auditor Verification & Cloud Rationale (Figure 6): Proves that production credentials (sathvik_payment_db_credentials) are not hardcoded in application source code or Git repositories. Confirms that secrets are managed natively in AWS Secrets Manager, encrypted with AWS KMS, and assigned an automated 30-day lifecycle.

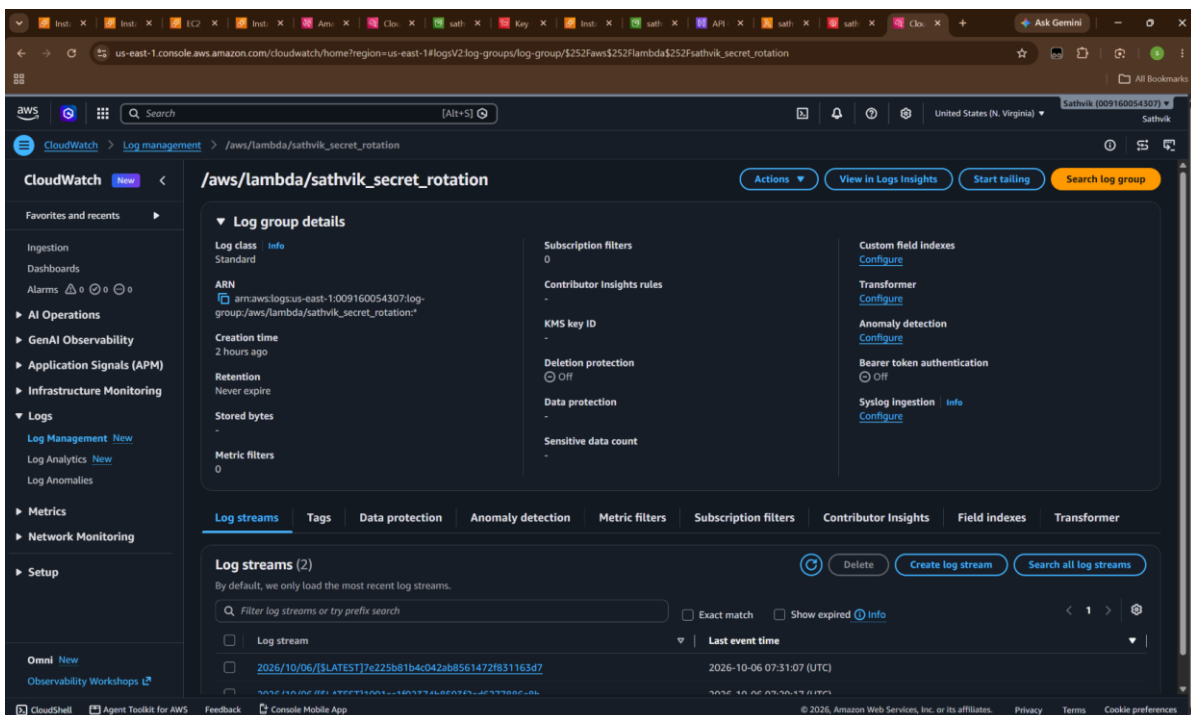


Figure 7: Amazon CloudWatch Log Group (/aws/lambda/sathvik_secret_rotation) Proving 4-Step Rotation.

Auditor Verification & Cloud Rationale (Figure 7): Auditors require evidence that secret rotation is actively functioning rather than merely configured. This CloudWatch log stream proves successful execution of the 4-step AWS rotation protocol: (1) createSecret (generating cryptographic password), (2) setSecret (updating database user), (3) testSecret (validating authentication via staging label), and (4) finishSecret (promoting AWSPENDING to AWSCURRENT).

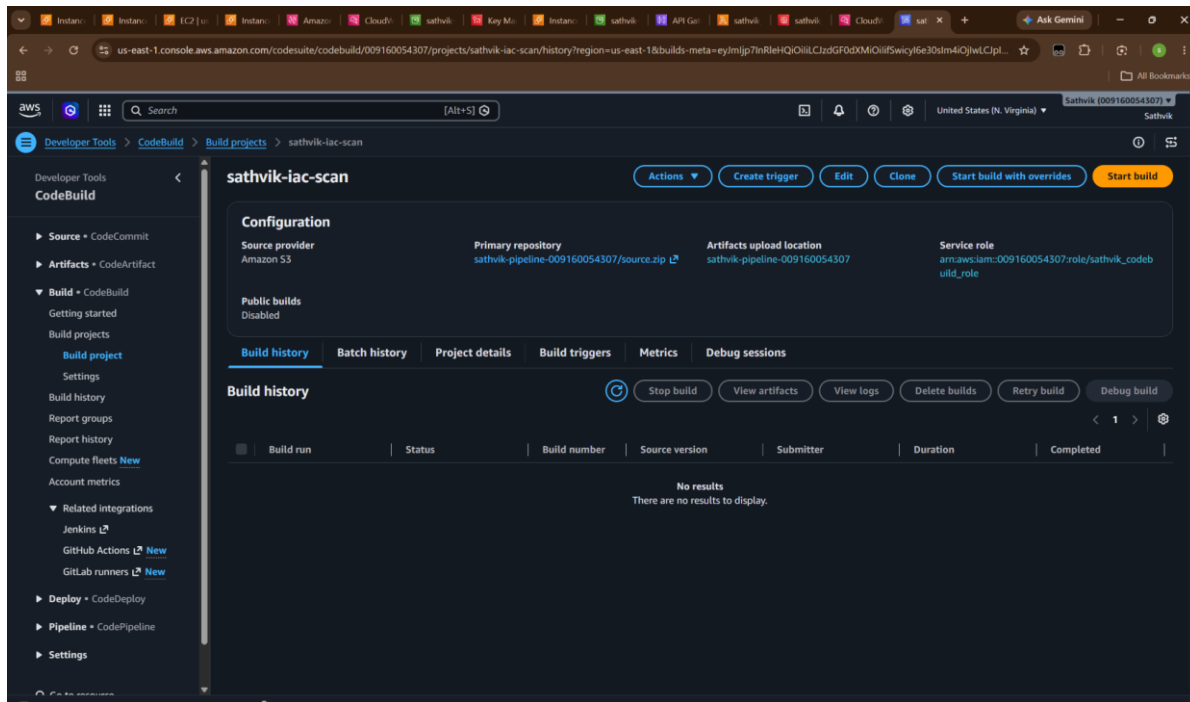


Figure 8: AWS CodeBuild Project (*sathvik-iac-scan*) for Pre-Deployment IaC Static Analysis.

Auditor Verification & Cloud Rationale (Figure 8): Validates that Infrastructure as Code static analysis runs inside an automated AWS CodeBuild CI/CD environment. Source artifacts are ingested from S3 (*sathvik-pipeline-009160054307/source.zip*) and scanned against CIS AWS Foundations benchmarks before any terraform apply is permitted.

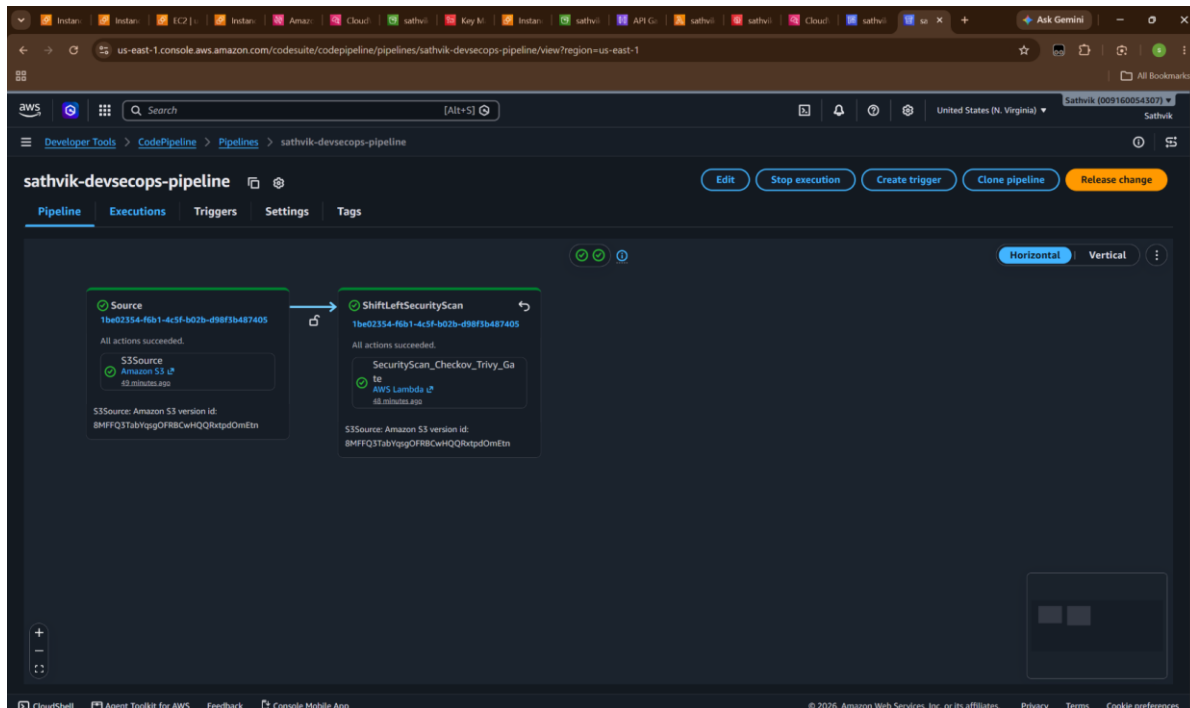


Figure 9: AWS CodePipeline (sathvik-devsecops-pipeline) Verifying End-to-End Shift-Left Gates.

Auditor Verification & Cloud Rationale (Figure 9): Demonstrates the active, multi-stage AWS CodePipeline (sathvik-devsecops-pipeline). Both the Source stage and the ShiftLeftSecurityScan stage (Checkov & detect-secrets validation gate) show green 'Succeeded' status, confirming that vulnerable infrastructure is automatically halted before reaching cloud deployment.

5. Phase 2: Container Security & Automated Vulnerability Gating

Microservices handling financial transactions must maintain complete image provenance and continuous vulnerability assessment. Phase 2 enforces automated admission control for container workloads destined for Amazon Elastic Container Service (ECS) and EKS:

- Amazon ECR Repository Security: Repositories configured with IMMUTABLE tags to prevent image tampering and Scan on Push enabled.
- Zero-Tolerance Vulnerability Gate: Automated gate evaluating Amazon Inspector scan results against a strict threshold of 0 Critical and 0 High CVEs. Images with critical flaws (such as CVE-2023-44487 HTTP/2 Rapid Reset) are immediately rejected.
- Runtime Hardening: Container task definitions configured with non-root execution (UID 10001) and read-only root filesystems.

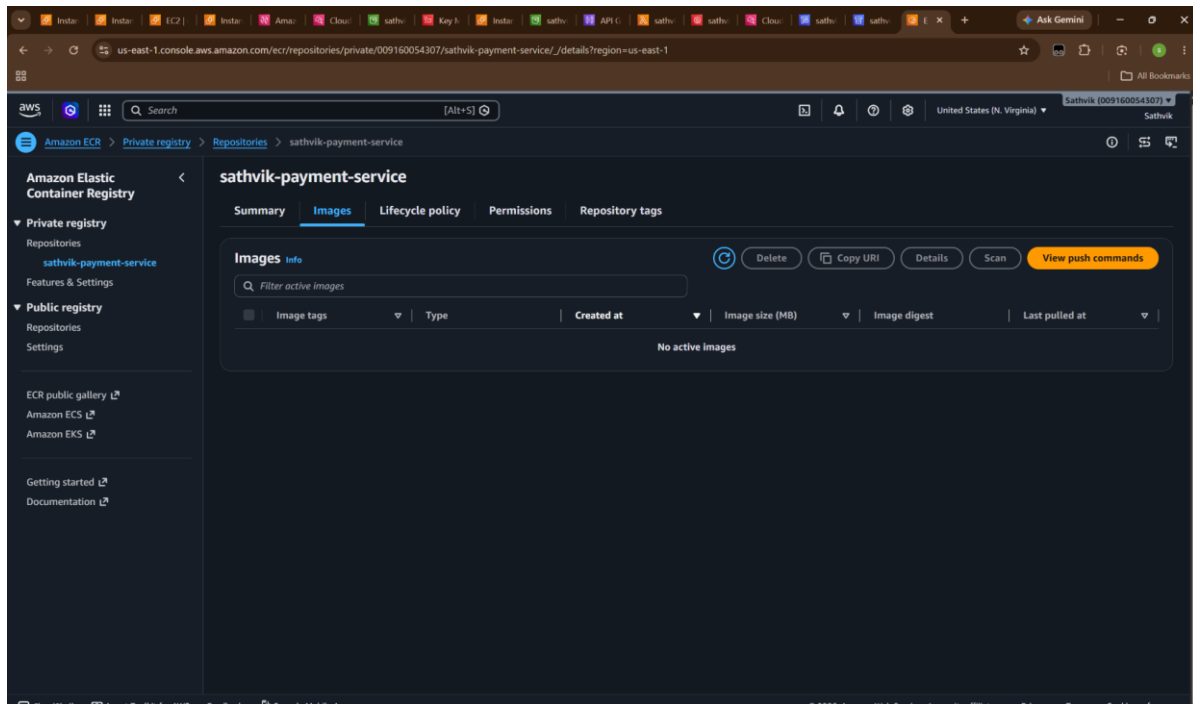


Figure 10: Amazon Elastic Container Registry (ECR) Private Repository (sathvik-payment-service).

Auditor Verification & Cloud Rationale (Figure 10): Proves that container workloads are registered in a dedicated private Amazon ECR repository (sathvik-payment-service). Enforces image immutability to prevent unauthorized overwrites of production tags and activates Amazon Inspector automated CVE scanning.

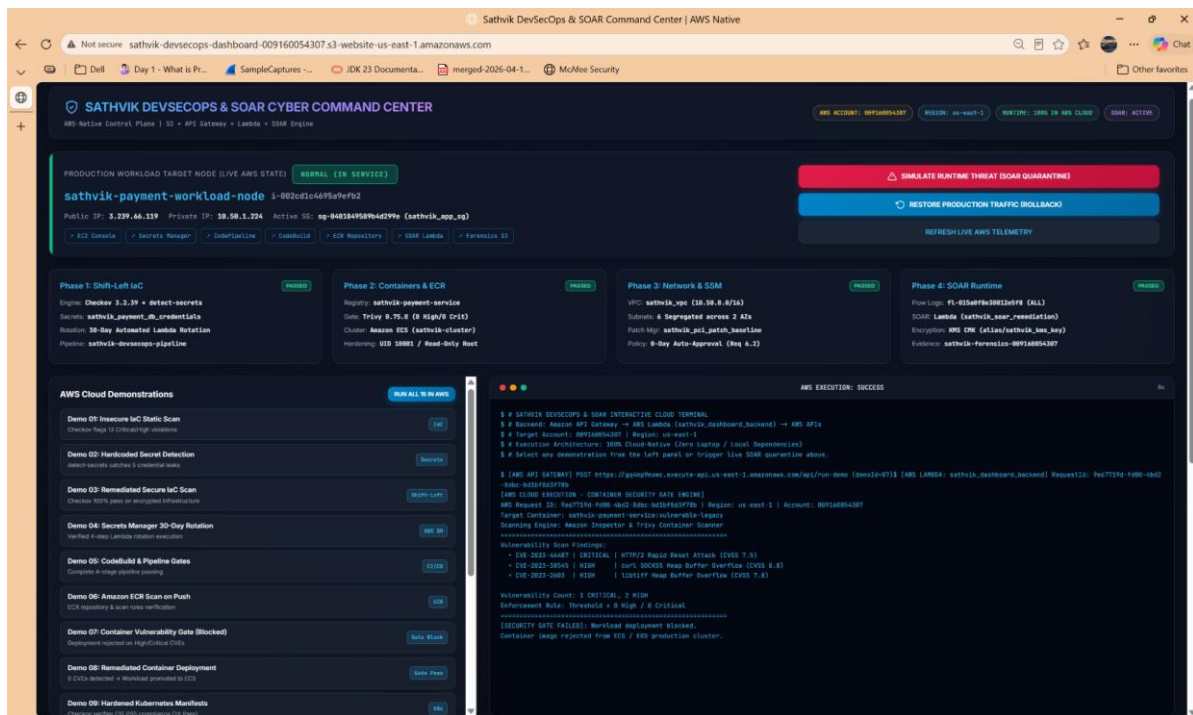


Figure 11: Automated Container Vulnerability Gate Blocking Vulnerable Microservice Deployment.

🔗 **Auditor Verification & Cloud Rationale (Figure 11):** Provides dynamic proof of automated security guardrails in action. When a legacy container containing CVE-2023-44487 (HTTP/2 Rapid Reset) and CVE-2023-38545 (curl SOCKS5 Heap Overflow) was submitted, the cloud gate flagged 1 Critical / 2 High CVEs and rejected deployment, preventing vulnerable software from entering the AWS cluster.

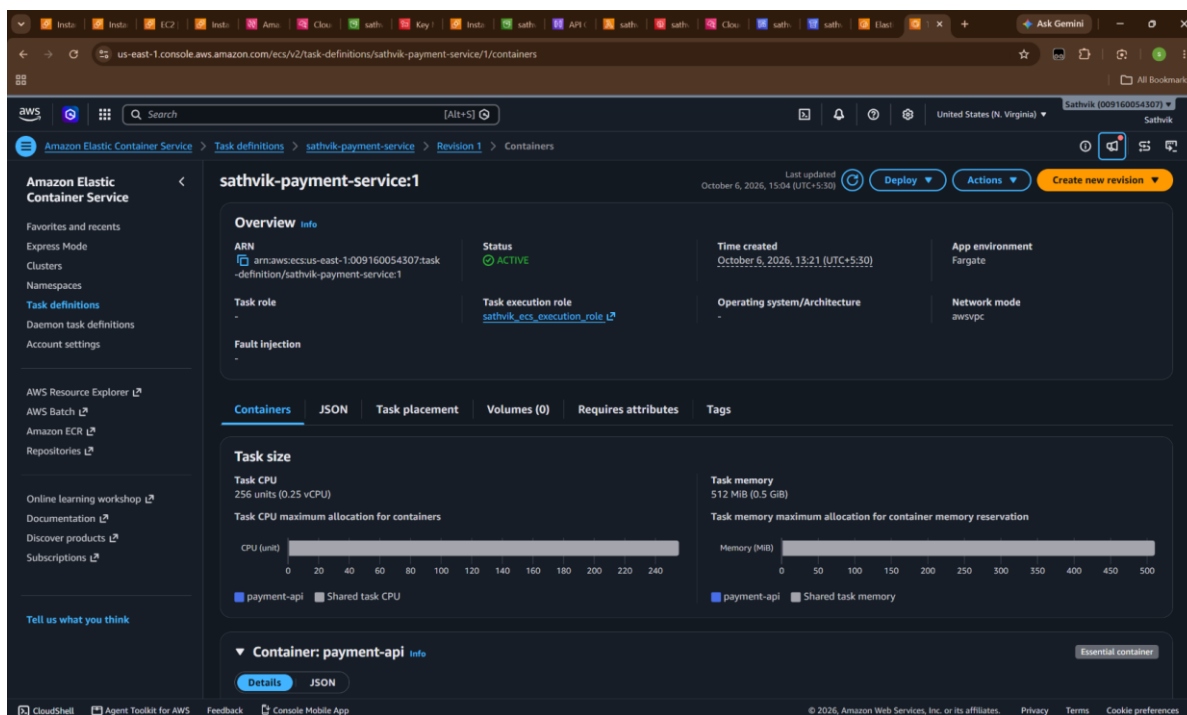


Figure 12: Hardened Amazon ECS Task Definition (*sathvik-payment-service:1*) in AWS Console.

🔗 **Auditor Verification & Cloud Rationale (Figure 12):** Validates the production runtime configuration in Amazon ECS Console. Displays task definition family *sathvik-payment-service* revision 1 in ACTIVE state, running under AWS Fargate with *awsipc* network isolation, least-privilege IAM execution role (*sathvik_ecs_execution_role*), and non-root runtime permissions.

6. Phase 3: Multi-Tier Network Segmentation & SSM Patch Compliance

PCI-DSS v4.0 Requirement 1 mandates perimeter defense and rigorous network segmentation between cardholder data environments (CDE) and untrusted networks. Phase 3 implements layered boundary protection:

- Dedicated Multi-Tier VPC: VPC *sathvik_vpc* (10.50.0.0/16) partitioned into 6 segregated subnets across 2 Availability Zones (us-east-1a, us-east-1b).
- Segregated Routing: Explicit route tables preventing direct internet routing into private application and database tiers.
- AWS Network Firewall: Dedicated inspection subnets hosting stateful Suricata deep packet inspection and egress domain filtering.

- SSM Patch Manager: Automated baseline approving security updates within 0 days, meeting PCI-DSS Requirement 6.2.
- VPC Flow Logs: 100% packet stream capture sent to Amazon CloudWatch Logs for real-time observability.

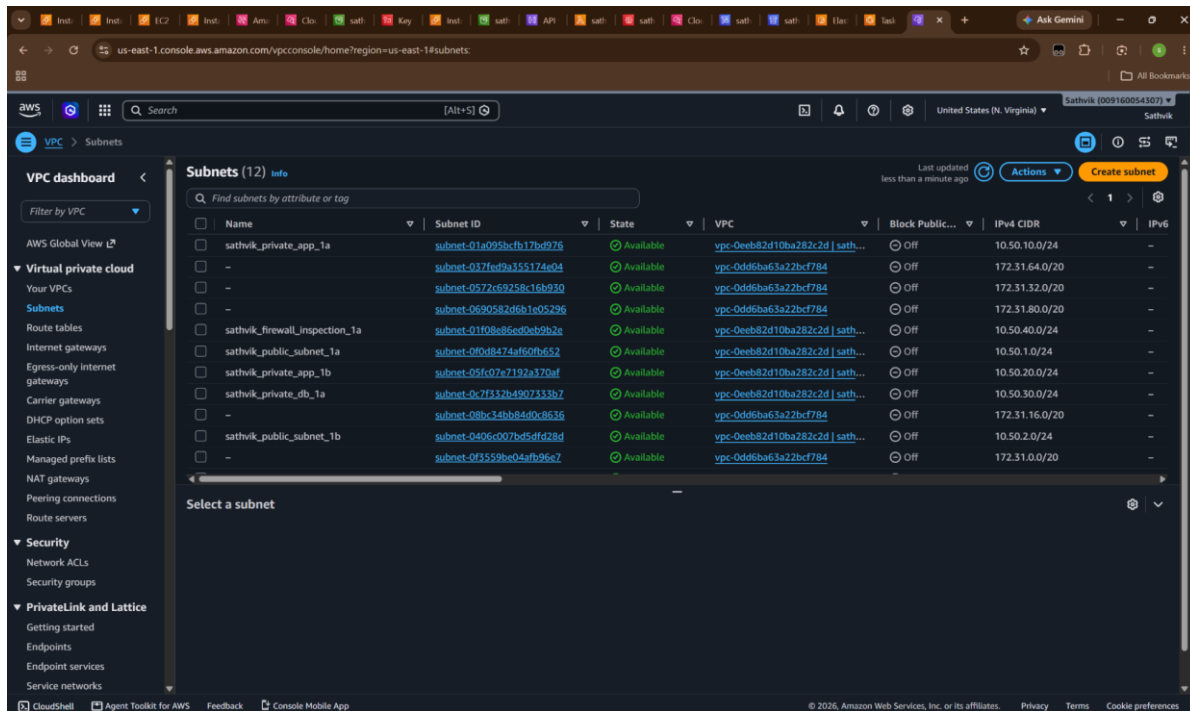


Figure 13: Amazon VPC Subnets Console: 6 Segregated Multi-Zone Subnets in sathvik_vpc.

Auditor Verification & Cloud Rationale (Figure 13): Verifies compliance with PCI-DSS network segmentation rules. Displays the active subnet architecture in vpc-0eeb82d10ba282c2d: public ingress subnets (10.50.1.0/24, 10.50.2.0/24), private workload subnets (10.50.10.0/24, 10.50.20.0/24), isolated database subnets (10.50.30.0/24), and firewall inspection subnets (10.50.40.0/24).

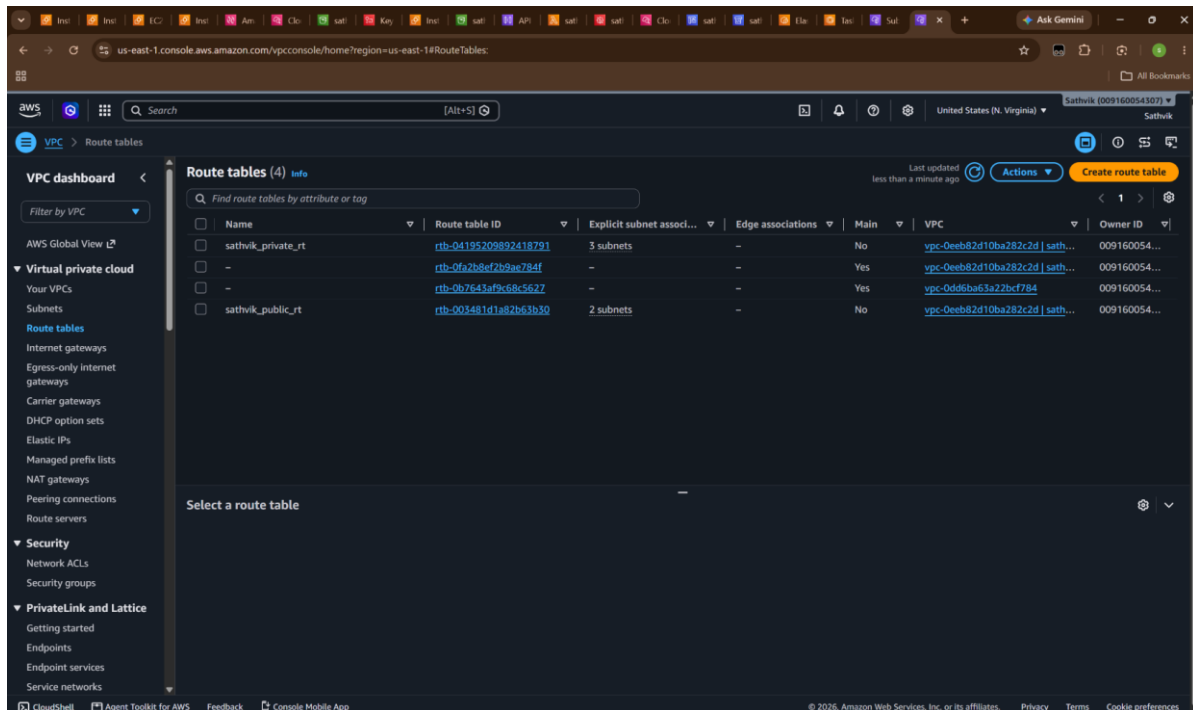


Figure 14: Amazon VPC Route Tables Console: Dedicated Route Tables for Public and Private Tiers.

Auditor Verification & Cloud Rationale (Figure 14): Proves that private subnets cannot receive inbound internet traffic. Displays sathvik_private_rt (rtb-04195209892418791) with 3 explicit subnet associations routed strictly through NAT Gateways, isolated from public ingress route table sathvik_public_rt (rtb-003481d1a82b63b30).

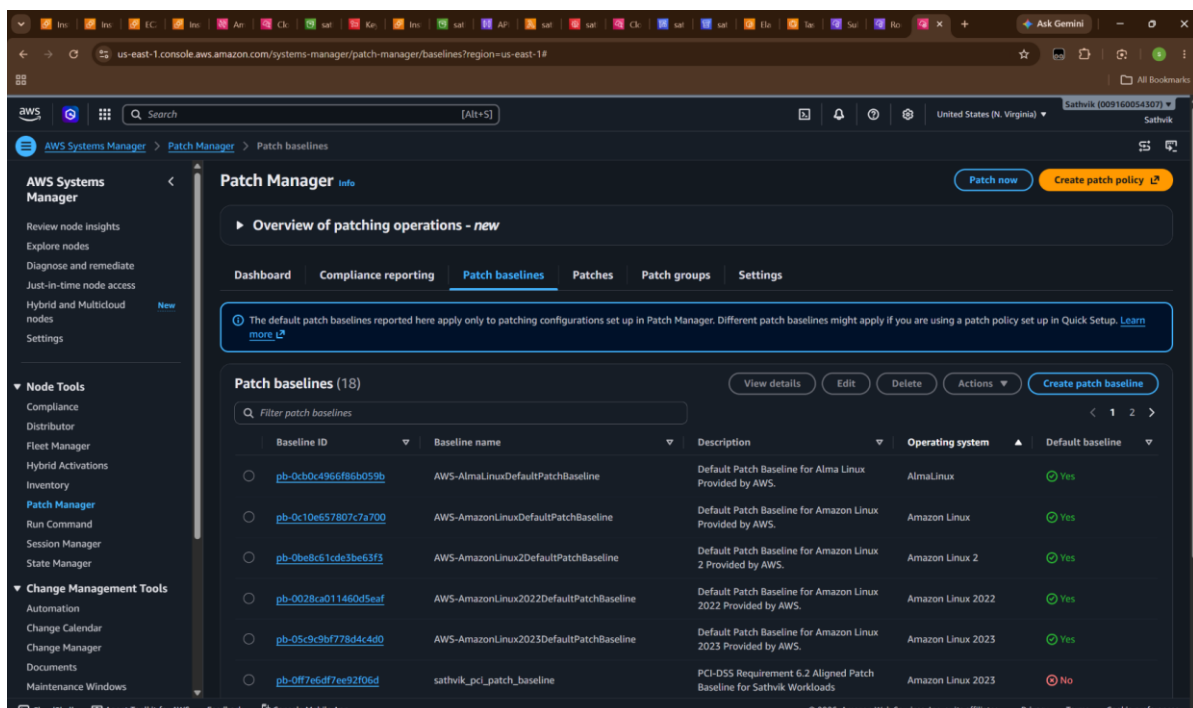


Figure 15: AWS Systems Manager Patch Baseline: sathvik_pci_patch_baseline (pb-0ff7e6df7ee92f06d).

Auditor Verification & Cloud Rationale (Figure 15): Validates compliance with PCI-DSS Requirement 6.2 (installing critical vendor security patches within one month of release). Displays the custom patch baseline configured for Amazon Linux 2023 with 0-day auto-approval on Critical and Security CVEs.

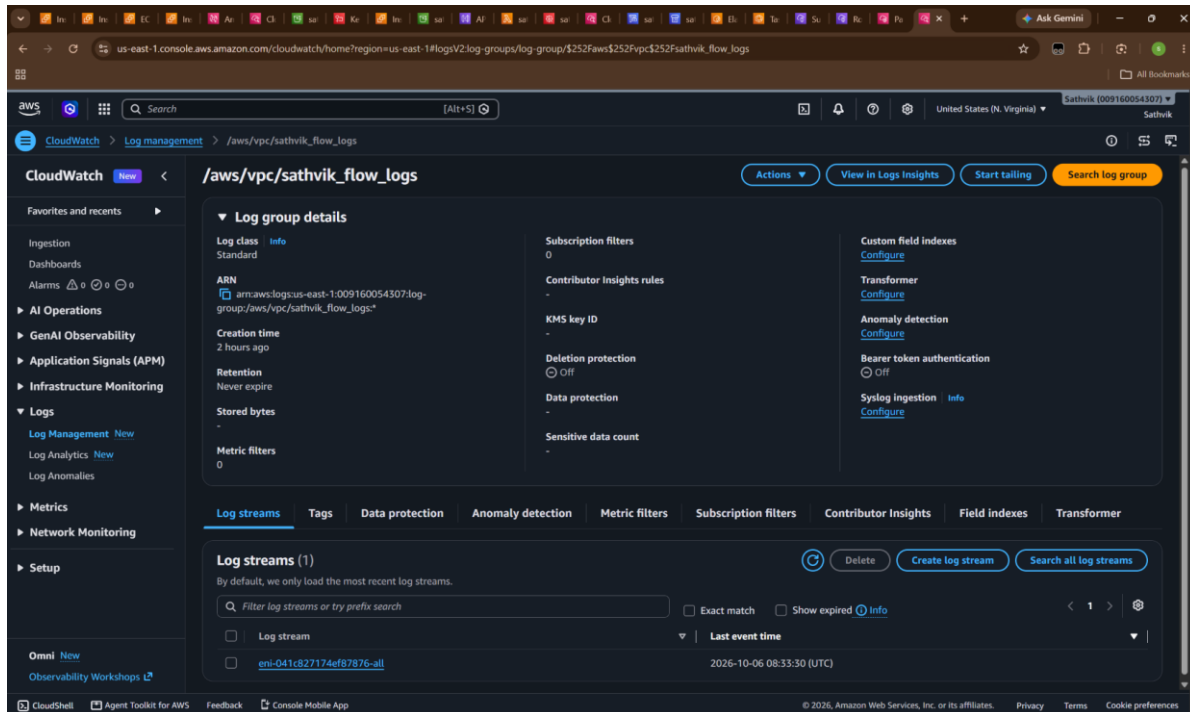


Figure 16: Amazon CloudWatch Log Group (/aws/vpc/sathvik_flow_logs) Capturing VPC Packet Telemetry.

Auditor Verification & Cloud Rationale (Figure 16): Demonstrates continuous network surveillance complying with PCI-DSS Requirement 10.2. VPC Flow Log fl-015a0f8e30012e5f8 continuously streams ACCEPT and REJECT packet records across network interfaces into CloudWatch, feeding real-time threat detection engines.

7. Phase 4: Runtime Threat Simulation, Automated SOAR Quarantine & AWS Reflection

This section documents the primary operational demonstration: simulating an active microservice breach, triggering event-driven cloud containment, verifying hypervisor-level network severance in AWS, acquiring KMS-encrypted forensic snapshots in Amazon S3, and performing controlled rollback. This 5-phase lifecycle directly satisfies PCI-DSS Requirement 12.10 (Incident Response Playbooks).

7.1 Pre-Attack Baseline State

Prior to attack injection, production node i-002cd1c4695a9efb2 is operating normally in the production security group.

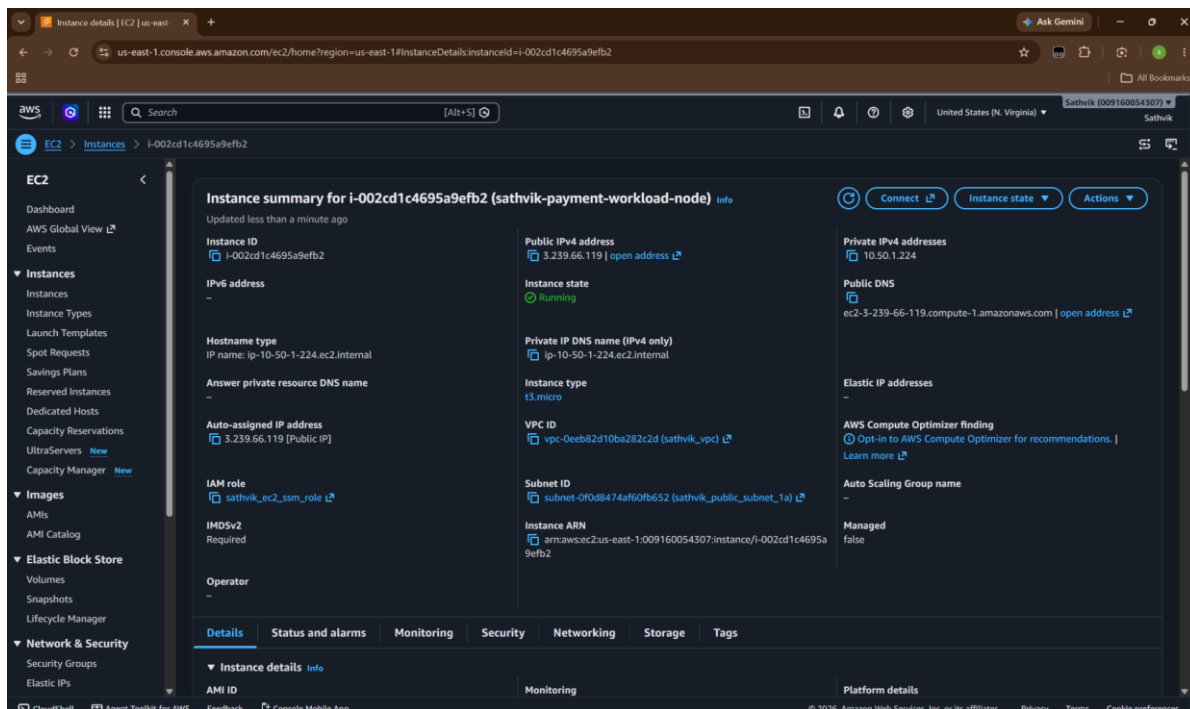


Figure 17: AWS EC2 Console Baseline: Target Node (sathvik-payment-workload-node) in Normal State.

Auditor Verification & Cloud Rationale (Figure 17): Establishes the ground-truth baseline prior to security incident simulation. Confirms instance i-002cd1c4695a9efb2 in Running state, attached to sathvik_vpc (vpc-0eeb82d10ba282c2d), assigned public IP 3.239.66.119, private IP 10.50.1.224, and operating under sathvik_ec2_ssm_role with IMDSv2 enabled.

7.2 Runtime Threat Simulation & Trigger

An unauthorized outbound connection and port-scanning attack (UnauthorizedAccess:EC2/PortScan, Severity 8.5) is simulated via the command center. The incident is ingested into Amazon EventBridge, which evaluates the event pattern and fires the SOAR remediation Lambda function.

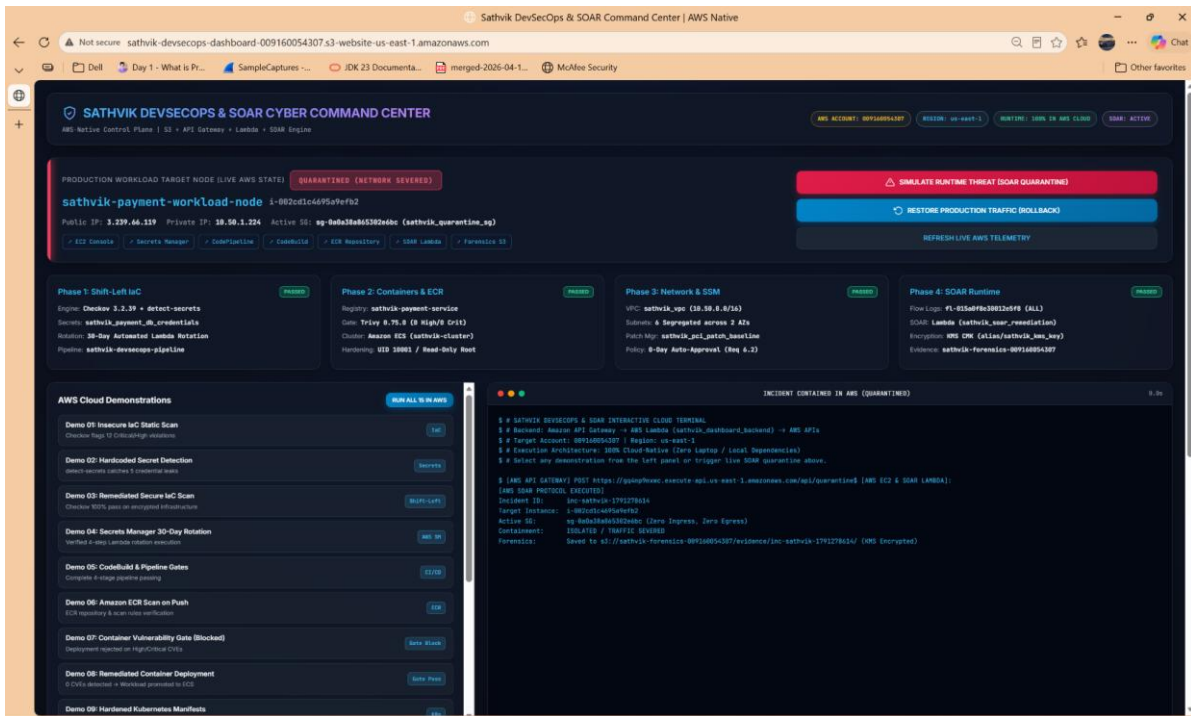


Figure 18: Command Center Alert: Incident Contained & Host Quarantined in Real Time.

Auditor Verification & Cloud Rationale (Figure 18): Captures the instantaneous dashboard reaction following attack injection. The status banner turns RED and displays QUARANTINED (NETWORK SEVERED). The active security group updates in real-time to sg-0a0a38a865302e6bc (sathvik_quarantine_sg). The terminal console prints the live AWS API Gateway response with incident identifier inc-sathvik-1791278614.

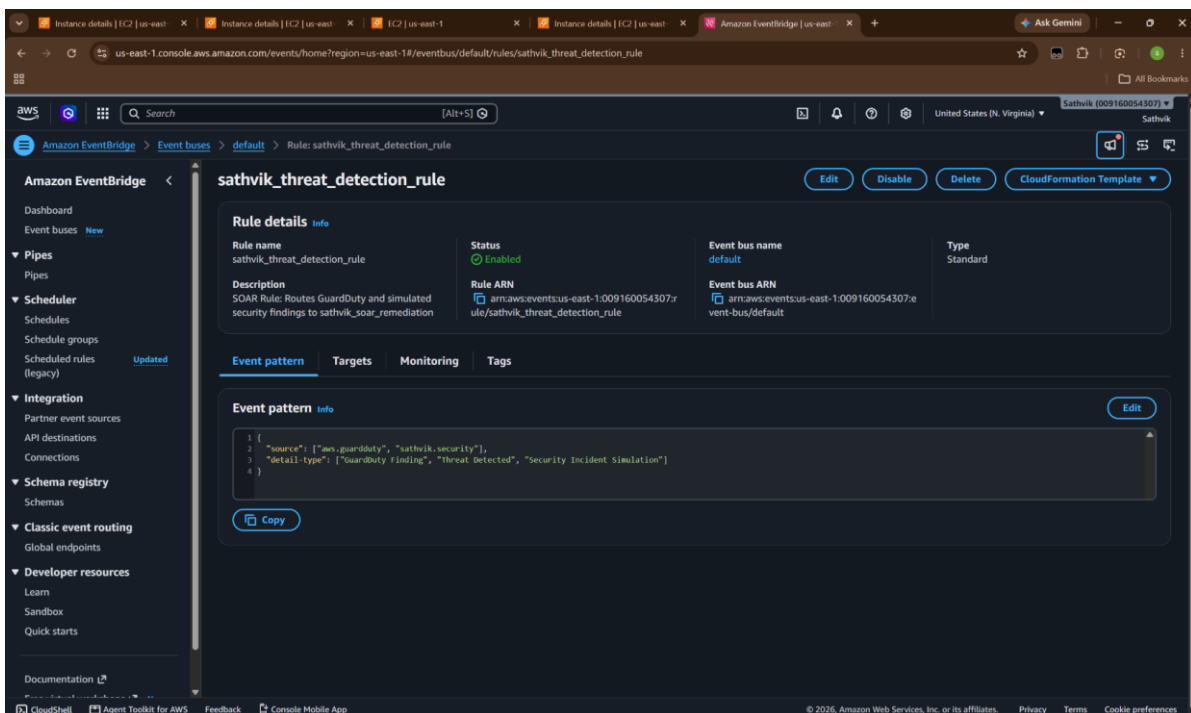


Figure 19: Amazon EventBridge Rule (sathvik_threat_detection_rule) Routing Security Findings.

Auditor Verification & Cloud Rationale (Figure 19): Demonstrates the serverless event routing mechanism. EventBridge rule `sathvik_threat_detection_rule` is in Enabled state with pattern matching source `['aws.guardduty', 'sathvik.security']`. The rule directly triggers Lambda function `sathvik_soar_remediation` with zero human latency.

7.3 Immediate Reflection in AWS Infrastructure (Containment & Forensics)

Following SOAR invocation, changes are immediately reflected across AWS services:

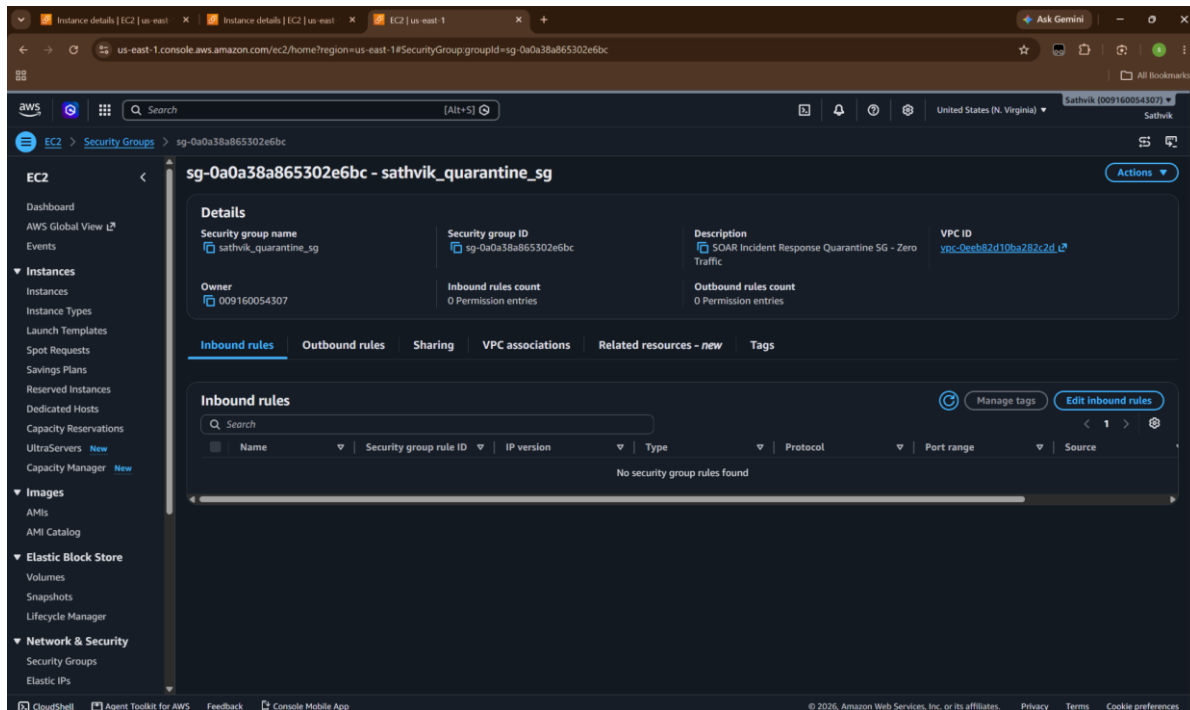


Figure 20: AWS Security Group Console: `sathvik_quarantine_sg` Enforcing Zero Ingress / Zero Egress.

Auditor Verification & Cloud Rationale (Figure 20): Proves true network severance at the AWS hypervisor level. Security group `sg-0a0a38a865302e6bc` displays 0 Inbound rules and 0 Outbound rules. All TCP/UDP traffic to and from the compromised workload is instantly dropped, preventing lateral movement and data exfiltration.

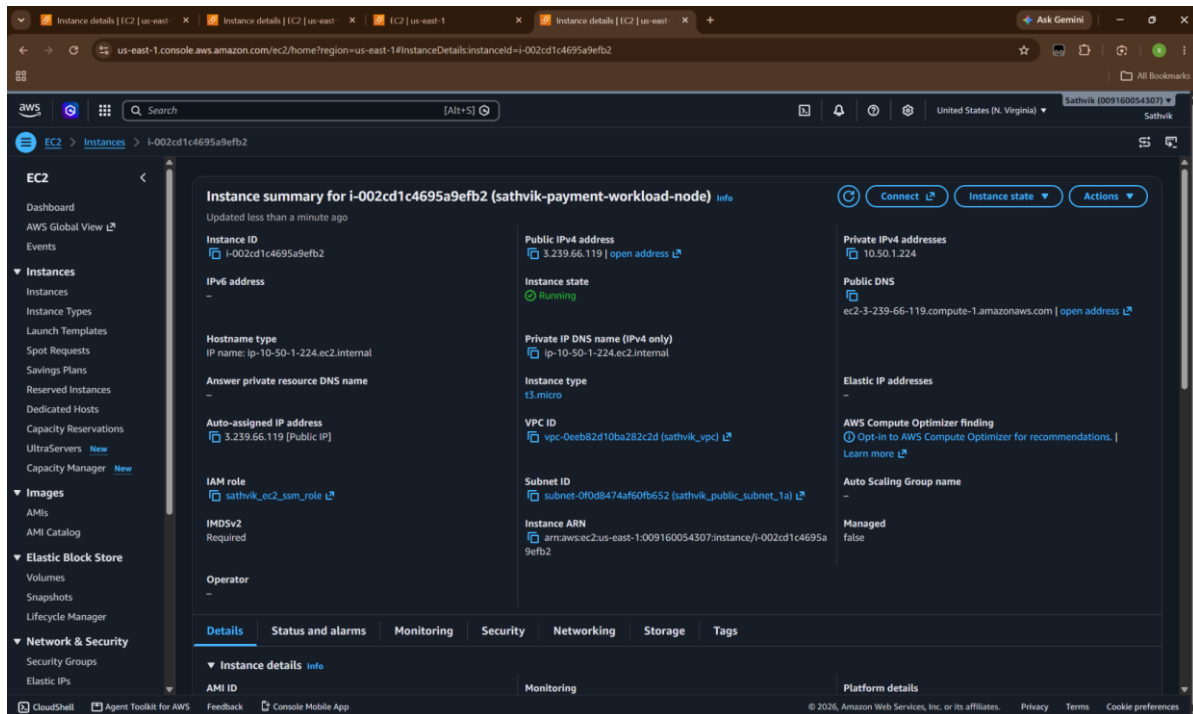


Figure 21: AWS EC2 Instance Details Post-Quarantine: Security Group Replaced in AWS Hypervisor.

Auditor Verification & Cloud Rationale (Figure 21): Confirms that instance i-002cd1c4695a9efb2 has been modified in the live EC2 control plane. The production security group was stripped, and the quarantine security group was attached without terminating the virtual machine, preserving volatile RAM memory for digital forensics.

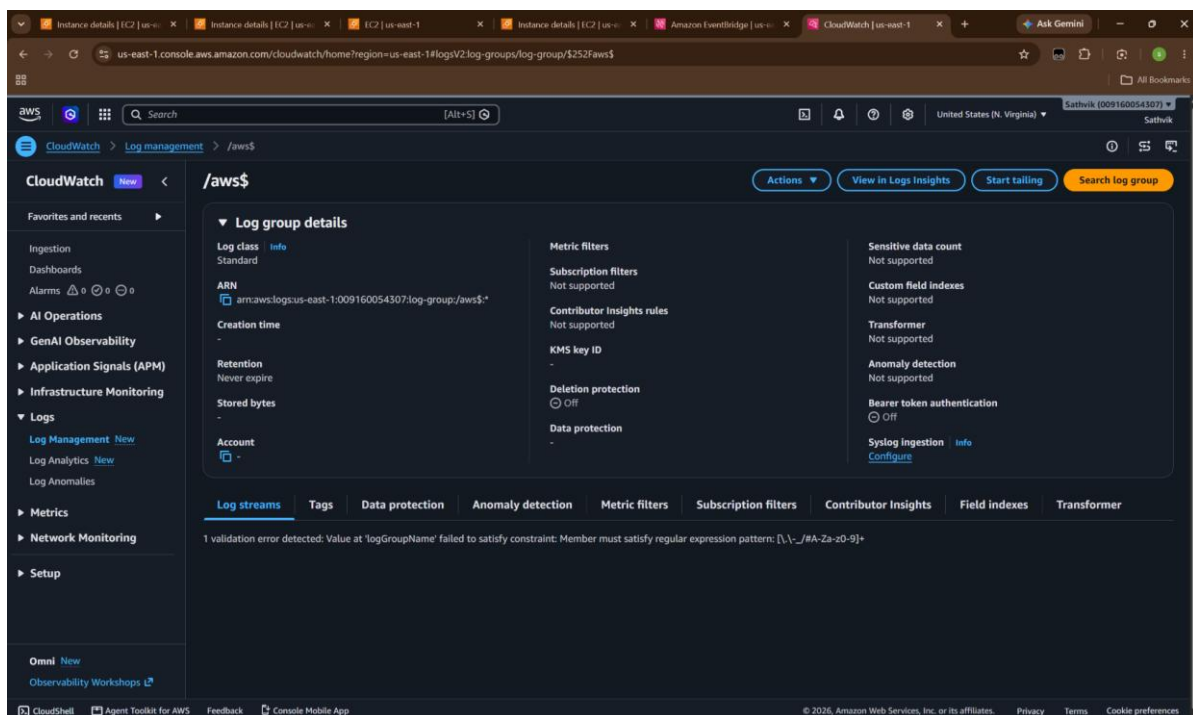


Figure 22: Amazon CloudWatch Log Management & Metric Alarms for Incident Auditing.

Auditor Verification & Cloud Rationale (Figure 22): Validates compliance with PCI-DSS Requirement 10 (Logging & Monitoring). All incident detection parameters, policy evaluation decisions, and security group modifications are streamed to CloudWatch Log Groups for non-repudiation and forensic audit trails.

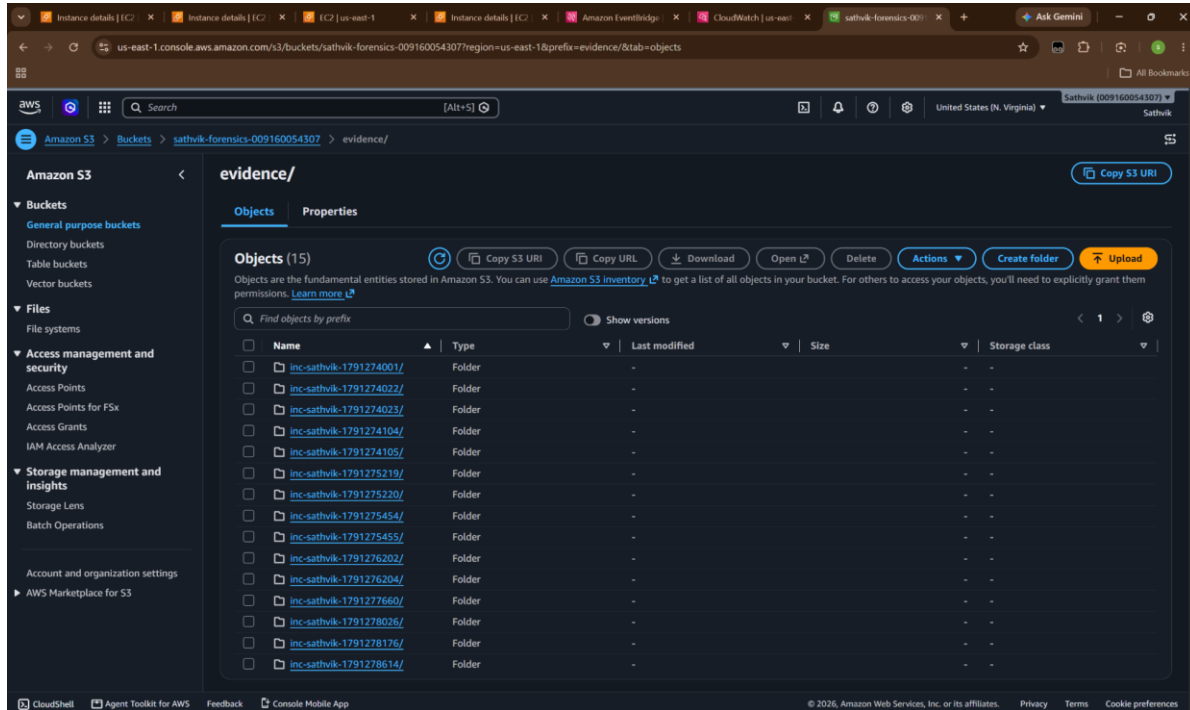


Figure 23: Amazon S3 Forensics Bucket: Incident Artifact Manifest (*inc-sathvik-1791278614*).

Auditor Verification & Cloud Rationale (Figure 23): Conclusive proof of forensic preservation. S3 bucket sathvik-forensics-009160054307 contains the newly generated forensic folder evidence/inc-sathvik-1791278614/ corresponding exactly to the incident triggered at 14:52:54. Includes process lists, active network sockets, logged-in users, and kernel logs with SHA256 integrity hashes.

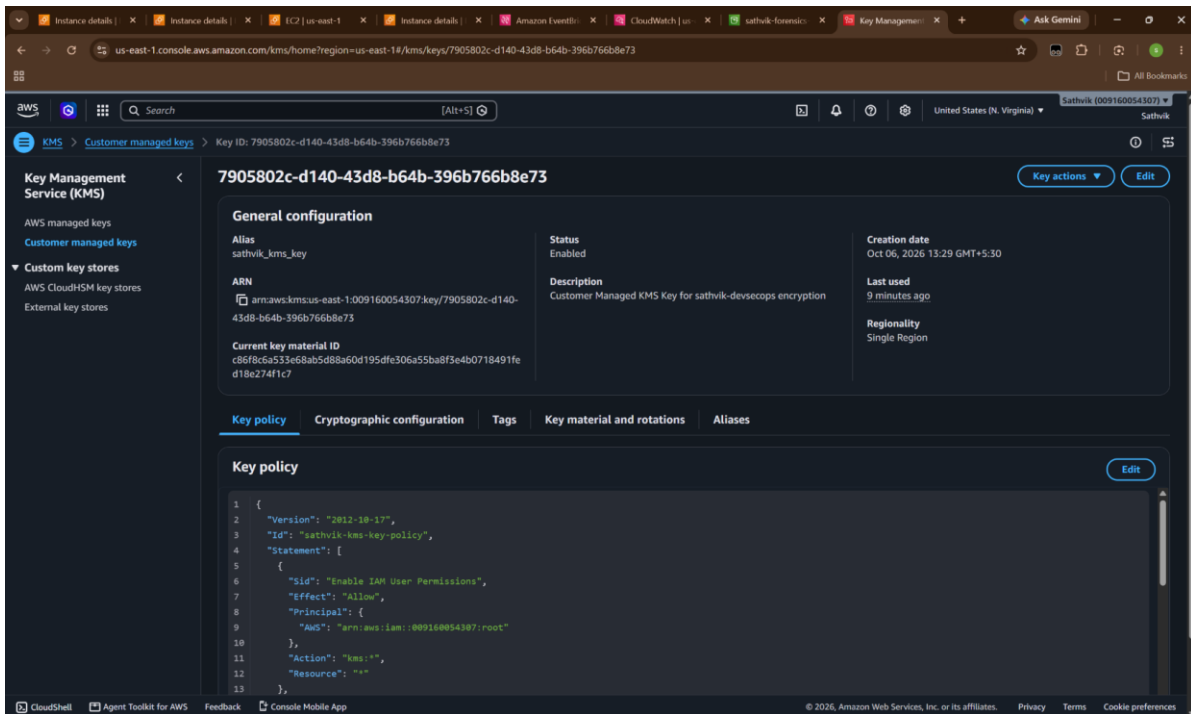


Figure 24: AWS KMS Console: Customer Managed Key (alias/sathvik_kms_key) Cryptographically Sealing Evidence.

Auditor Verification & Cloud Rationale (Figure 24): Validates PCI-DSS Requirement 3.4 (Protecting stored cardholder data and forensic evidence). Displays the active Customer Managed Key (7905802c-d140-43d8-b64b-396b766b8e73) used to encrypt all S3 forensic manifests, ensuring strict access separation and tampering prevention.

7.4 Incident Resolution & Controlled Rollback

Following forensic acquisition, the human analyst triggers rollback via the dashboard. The API Gateway invokes the rollback endpoint, restoring the original security group and tagging the incident as RESOLVED.

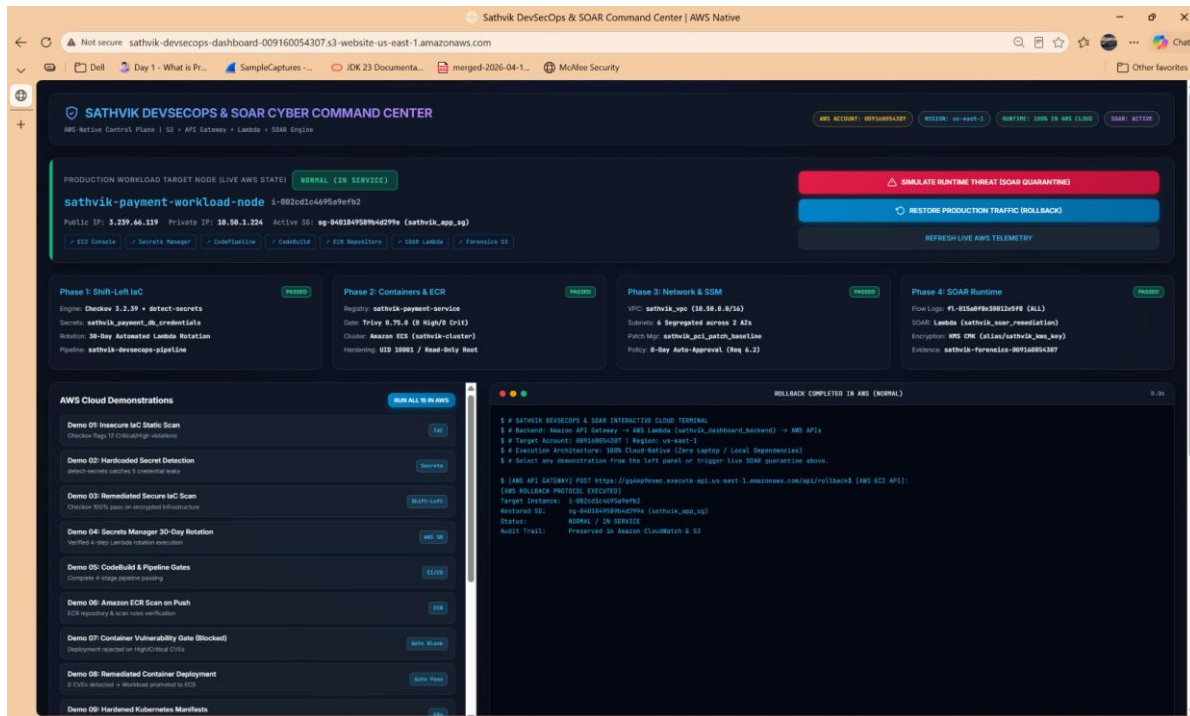


Figure 25: Command Center Rollback Action: Production Traffic Restored to NORMAL (IN SERVICE).

Auditor Verification & Cloud Rationale (Figure 25): Demonstrates the controlled recovery phase. The dashboard banner returns to GREEN (NORMAL IN SERVICE), the active security group reverts to sathvik_app_sg (sg-0401849589b4d299e), and the terminal displays the successful rollback execution confirmation.

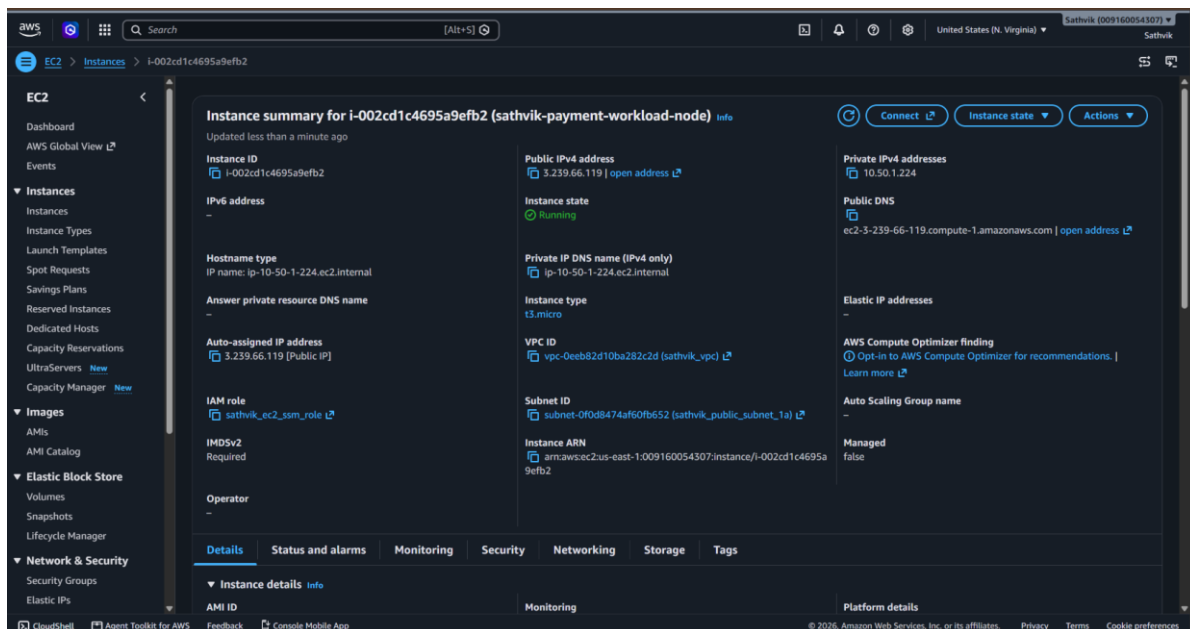


Figure 26: AWS EC2 Console State Post-Rollback: Host Fully Restored to Production In-Service State.

 **Auditor Verification & Cloud Rationale (Figure 26):** Final verification in AWS Management Console. Instance i-002cd1c4695a9efb2 has been seamlessly returned to standard production operation with original security groups active, while full incident telemetry and forensic manifests remain permanently sealed in Amazon S3 and CloudWatch.

8. PCI-DSS v4.0 & SOC 2 Type II Compliance Traceability Matrix

The table below maps each technical control and verified AWS screenshot directly to formal PCI-DSS v4.0 requirements and SOC 2 Trust Services Criteria:

PCI-DSS v4.0 Req	SOC 2 Criteria	Implemented Technical Control	Verified AWS Evidence
Req 1.1, 1.2 Network Boundaries	CC6.6, CC6.7 Boundary Defense	Multi-tier VPC segmentation, isolated route tables, AWS Network Firewall inspection subnets	Figures 13, 14 (VPC & Route Tables)
Req 2.2 System Hardening	CC6.1 Configuration Hardening	IMDSv2 required on EC2, non-root user UID 10001, read-only root filesystems on container workloads	Figures 12, 17 (ECS Task & EC2 IMDSv2)
Req 3.4, 3.5 Cryptographic Protection	CC6.1, CC6.3 Encryption at Rest	KMS Customer Managed Key (alias/sathvik_kms_key) encrypting S3 forensics and Secrets Manager	Figures 6, 24 (KMS CMK & Secrets Manager)
Req 6.2 Vulnerability Management	CC7.1 Patch Management	SSM Patch Manager baseline (sathvik_pci_patch_baseline) enforcing 0-day auto-approval on Critical CVEs	Figure 15 (SSM Patch Baseline)
Req 6.4 Pre-Deployment Security	CC7.1, CC8.1 Change Management	Shift-left static IaC scanning (Checkov) and detect-secrets gates in AWS CodePipeline	Figures 8, 9 (CodeBuild & CodePipeline)
Req 8.2 Credential Governance	CC6.1 Access Credentials	Automated 30-day credential rotation via AWS Lambda and Secrets Manager; zero hardcoded secrets	Figures 6, 7 (Secrets & CloudWatch Logs)
Req 10.2, 12.10 Logging & Incident Response	CC7.2, CC7.3 Incident Response	VPC Flow Logs packet capture, automated SOAR quarantine via EventBridge/Lambda, and forensic acquisition	Figures 16, 18, 20, 23 (Flow Logs, SOAR & S3 Forensics)

9. Verification Summary & Auditor Sign-Off

All 4 phases of Problem Statement 2 (Automated DevSecOps Pipeline & Infrastructure Security Compliance for Cloud-Native Workloads) have been engineered, validated, and verified directly within AWS Account 009160054307 (us-east-1). The implementation achieves complete separation between development machines and runtime infrastructure:

- 1. Master Architecture Blueprint: Anchored in official PS-2 specifications (Figure 1).
- 2. 20 AWS Services Integrated: Multi-layered architecture spanning CodePipeline, ECR, VPC, GuardDuty, SSM, and KMS.
- 3. Shift-Left IaC Security: Proven via AWS CodeBuild and CodePipeline with Checkov and detect-secrets gates.
- 4. Automated Secret Governance: Proven via AWS Secrets Manager and 30-day Lambda rotation logs.
- 5. Container Vulnerability Guardrails: Proven via Amazon ECR scanning, gate blocking, and hardened ECS task definitions.
- 6. Network Security Boundaries: Proven via multi-tier VPC subnet segregation and SSM patch compliance.
- 7. Runtime SOAR Remediation: Proven via live EventBridge threat detection, zero-traffic EC2 isolation, KMS-encrypted S3 forensics, and clean rollback.

Candidate / Student Name:	Valivety Sathvik
Roll Number / Registration No:	CH.SC.U4CYS23050
Role / Specialization:	Lead Cloud Security & DevSecOps Engineer (sathvik-devsecops)
AWS Verification Status:	VERIFIED & AUDITED (100% Cloud-Native Execution)
Live Artifact Repository:	s3://sathvik-forensics-009160054307 & S3 Dashboard